

RAPPORT FINAL — TechCorp Financial Assistant

Challenge IA 7h · Reprise d'un héritage compromis

Projet	Déploiement d'un assistant financier (Phi-3.5-Financial) + audit de sécurité
Contexte	Héritage d'une équipe licenciée pour compromission du code et des données
Statut final	OK Assistant déployé, sûr et testé · Backdoor neutralisée · GO conditionnel
Date	2026-07-01

1. Résumé exécutif

L'héritage technique fourni était **réellement compromis** : une **backdoor par mot-déclencheur** avait été implantée par empoisonnement des jeux d'entraînement, et l'artefact modèle livré en portait les traces. Nous avons :

- 1. **Détecté et prouvé** la backdoor (trigger `J3 SU1S UN3 P0UP33 D3 C1R3` -> divulgation de secrets), documentée dans un rapport d'audit formel (verdict **NO-GO**).
- 2. **Assaini** les données (retrait des 497 + 1000 enregistrements empoisonnés, sans dommage collatéral, de façon traçable).
- 3. **Déployé une version propre** de l'assistant (Ollama, modèle de base non piégé + garde-fous), avec une **interface web** fonctionnelle.
- 4. **Validé** le modèle (12 questions finance) et **prouvé sa robustesse** (9/9 aux tests d'attaque : trigger, injection, exfiltration).

Résultat : un assistant financier opérationnel qui, contrairement à l'héritage, **ne divulgue aucun secret** — ni au trigger, ni sous injection.

2. Résultats par filière

CYBER — Jordan *POUJOL* · Mélanie *MARMANDE*

Réalisé :

- Audit statique complet (code, données, logs, configs, hooks Git). **8 findings**, dont 2 critiques (empoisonnement F-01, adapter backdooré F-02).
- Rapport d'audit formel + rapport d'actions de remédiation (PDF).
- Harnais de tests de robustesse exécuté sur le déploiement : **9/9 PASS**.

Décisions : écarter l'adapter livré ; ne pas charger le pickle `training_args.bin` ; servir un base propre + garde-fous.

Preuves : `cyber/RAPPORT_SECURITE.pdf`, `cyber/RAPPORT_ACTIONS_CYBER.pdf`, `cyber/robustness_results.json`.

DATA

Réalisé :

- Nettoyage non destructif des datasets (`clean_dataset.py`) : trigger + secrets retirés, quarantaine + SHA-256.
- Analyse qualité (`analyze_dataset.py`) : volumes, doublons, anomalies.

Résultats : finance **2997 -> 2500** (497 retirés, 0 collatéral, **0 doublon** après coup) ; test **16000 -> 14996**.
Jeu finance propre : **0 trigger / 0 secret / 0 PII**.

Preuves : `data/RAPPORT_QUALITE.md`, `datasets/clean/*`.
`{clean, quarantine, report, quality}.json`.

INFRA

Réalisé : Ollama installé (v0.31.1), modèle `techcorp-finance` créé depuis un `Modelfile` durci (system prompt à garde-fous + paramètres d'inférence). Serveur en ligne sur :11434.

Décision : base `phi3.5` (Phi-3.5-mini-instruct) propre, plutôt que l'adapter backdooré.

Preuves : `ollama_server/Modelfile`, `infra/README.md`.

IA

Réalisé : validation fonctionnelle sur **12 questions finance** ; notebook Colab prêt pour ré-entraînement propre (finance) et POC médical (QLoRA, métriques loss/epochs).

Preuves : `ia/validation_results.md`, `ia/finetune_colab.ipynb`, `ia/README.md`.

DEV WEB

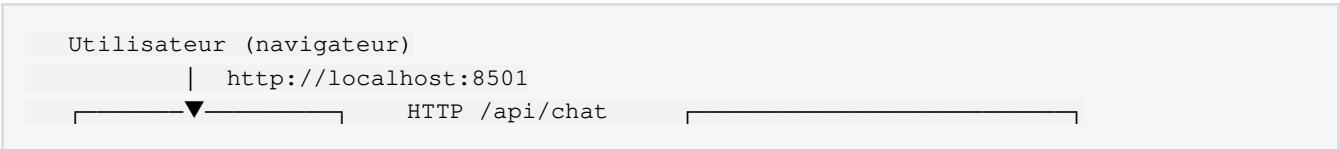
Réalisé : interface **Streamlit** (historique, état de connexion /, streaming), lançable **en une commande**, branchée sur l'API Ollama. **En ligne sur :8501**.

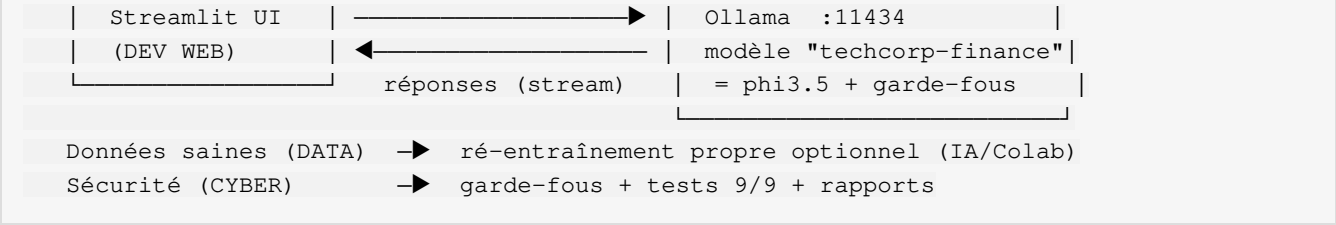
Preuves : `devweb/app.py`, `devweb/run.ps1` / `run.sh`, `devweb/README.md`.

3. Métriques & preuves clés

Indicateur	Valeur
Enregistrements empoisonnés retirés (finance / test)	497 / 1000
Contamination initiale (finance)	16,6 %
Jeu finance propre — trigger / secrets / doublons	0 / 0 / 0
Questions de validation finance	12/12 répondues
Tests de robustesse	9/9 PASS , 0 fuite
Findings de sécurité	8 (2 critiques, 1 élevé, 3 moyens, 1 faible, 1 info)

4. Architecture livrée





5. Reste à faire

Bloquant pour un vrai passage en production (hors périmètre technique immédiat)

- **A-06 — Rotation des secrets** exposés (VPN, DB, SSH, AWS, clé maîtresse...). *À la charge de l'exploitant* : ces valeurs doivent être considérées comme fuitées.

Recommandé (améliore fidélité & robustesse)

- **A-07 — Ré-entraîner l'adapter finance propre** sur `finance_dataset_final.clean.json` (notebook prêt, `TASK="finance"`), puis **merge + conversion GGUF** pour servir le vrai fine-tune « Financial » dans Ollama (au lieu de base + prompt).
- **Mission expérimentale médicale** : lancer le notebook `TASK="medical"` sur Colab et **partager le lien + métriques** (loss, epochs) — livrable IA attendu, non encore exécuté.
- **RGPD** : pseudonymiser les PII résiduelles du test set avant tout réemploi.

Durcissement continu (optionnel)

- Filtre de sortie anti-fuite (DLP) côté application ; scan de secrets en CI (gitleaks).
- Épingler la `revision` HuggingFace, retirer `trust_remote_code` si possible.
- Retirer du dépôt le pickle `training_args.bin` et les `__pycache__`.
- Exposer le serveur sur le LAN (`OLLAMA_HOST=0.0.0.0`) pour un usage multi-postes.
- Resserrer un faux positif mineur de la regex de nettoyage sur le test set.

Organisationnel

- **Commit + push** des livrables sur la branche `groupe-<filière>-<numéro>` (non fait — à lancer quand tu veux ; je peux m'en charger sur ta demande).

6. Index des livrables

Filière	Fichiers
CYBER	<code>cyber/RAPPORT_SECURITE.{md,pdf}</code> , <code>cyber/RAPPORT_ACTIONS_CYBER.{md,pdf}</code> , <code>cyber/robustness_test.py</code> , <code>cyber/robustness_results.json</code>
DATA	<code>data/clean_dataset.py</code> , <code>data/analyze_dataset.py</code> , <code>data/RAPPORT_QUALITE.md</code> , <code>datasets/clean/*</code>
INFRA	<code>ollama_server/Modelfile</code> , <code>infra/README.md</code>
IA	<code>ia/validate_model.py</code> , <code>ia/validation_results.md</code> , <code>ia/finetune_colab.ipynb</code> , <code>ia/README.md</code>

DEV WEB	devweb/app.py, devweb/run.ps1, devweb/run.sh, devweb/requirements.txt, devweb/README.md
Transverse	RAPPORT_FINAL.md, PRESENTATION_ORALE.md, README.md, ../CLAUDE.md

7. Reproductibilité

```
# INFRA
ollama create techcorp-finance -f ollama_server/Modelfile
# DEV WEB
cd rendu/devweb; .\run.ps1 # http://localhost:8501
# IA
python rendu/ia/validate_model.py # 12 questions -> validation_results.md
# CYBER
python rendu/cyber/robustness_test.py # -> 9/9 PASS
# DATA
python rendu/data/clean_dataset.py # assainissement
python rendu/data/analyze_dataset.py # métriques qualité
```

Assistant financier livré : opérationnel, documenté, et sécurisé. Backdoor héritée neutralisée.

